

Gestão de Riscos em TI para Empresas e Universidades: Metodologia Integrada, Orientada a Processos e Apoiada por Inteligência Artificial

MIGR-TI/IA — Metodologia Integrada de Gestão de Riscos de TI e Inteligência Artificial. Este relatório apresenta uma metodologia operacional completa que conecta objetivos estratégicos, processos de negócio, serviços de TI, ativos, dados, aplicações, infraestrutura, identidades, fornecedores, controles e cenários de risco — com governança humana sobre o uso de inteligência artificial em todas as fases.

Destinado a gestores de TI, CISOs, responsáveis por GRC, pesquisadores e dirigentes de empresas e instituições de ensino superior, o documento articula evidências da literatura científica, normas técnicas internacionais e a legislação brasileira (LGPD) em um roteiro de implantação aplicável a contextos corporativos e universitários.

Sumário Executivo

A gestão de riscos em TI eficaz começa no objetivo estratégico e no processo de negócio — não no inventário de ativos ou na matriz de calor. Esta constatação, convergente na literatura acadêmica e nas normas técnicas revisadas, fundamenta a MIGR-TI/IA: uma metodologia de sete fases que combina discovery orientado a processos, formulação discriminada de cenários, quantificação proporcional à materialidade, corte governado por quatro portões, tratamento baseado em economia marginal e uso responsável de inteligência artificial com supervisão humana obrigatória.

O relatório incorpora os dez artigos mais influentes identificados na revisão — com sinais de citações observados em repositórios e editoras em 17/09/2026 — e integra ISO/IEC 27005:2022, NIST CSF 2.0, NIST SP 800-30 Rev. 1, COBIT 2019, Open FAIR, NIST AI RMF 1.0, HECVAT/EDUCAUSE, MITRE ATT&CK, CISA KEV, FIRST EPSS e a LGPD brasileira.

10

Artigos Influentes

Literatura científica revisada com sinais de citação observados

7

Fases MIGR-TI/IA

Da governança ao monitoramento contínuo

4

Portões de Corte

Filtros governados para decisão de tratamento

10

Princípios

Orientadores da metodologia



Os sinais de citações são indicativos observados em páginas de editoras e repositórios em 17/09/2026, e não uma classificação bibliométrica universal. Bases distintas cobrem conjuntos diferentes, atualizam em momentos distintos e contam citações de modo diverso. Os padrões técnicos não entram no ranking de artigos, mas fundamentam a metodologia.

Literatura Científica de Referência

A revisão identificou dez artigos influentes pela recorrência temática nas revisões encontradas e pela visibilidade em citações em páginas de editoras e repositórios. A tabela a seguir apresenta posição, referência, sinal de citações observado, contribuição científica e aplicação metodológica na MIGR-TI/IA.

#	Referência	Sinal*	Contribuição	Aplicação na MIGR-TI/IA
1	Boehm (1991). <i>IEEE Software</i> , 8(1). DOI	~2.913	Ciclo contínuo: identificação, análise, priorização, planejamento, resolução e monitoramento	Estrutura de fases e revisão cíclica da metodologia
2	Cox (2008). <i>Risk Analysis</i> , 28(2). DOI	~1.600	Matrizes ordinais podem inverter prioridades e alocar recursos subotimamente	Fundamenta o uso de FAIR/Monte Carlo em lugar de matrizes isoladas
3	Gordon & Loeb (2002). <i>ACM TISSEC</i> , 5(4). DOI	~961	Decisão econômica e benefício marginal de controles	Portão C de corte: benefício incremental vs. custo
4	Spears & Barki (2010). <i>MIS Quarterly</i> , 34(3). DOI	~756	Participação de usuários e donos de processo melhora discovery e adoção	Fase 1-A e papéis: donos de processo no discovery e aceitação do residual
5	Webb et al. (2014). <i>Computers & Security</i> , 44. DOI	~302	Percepção, compreensão e projeção; coleta de informação em escala	Modelo de monitoramento dinâmico e KRIs (Fase 7)
6	Culot et al. (2021). <i>TQM Journal</i> , 33(7). DOI	~267	SGSI como sistema sociotécnico, governança e melhoria contínua	Fase 0 e princípio 9 (melhoria contínua)
7	Fenz et al. (2011). <i>CAIS</i> , 28(22). DOI	~93	Vínculo entre risco, controles, custos e decisão de investimento	Fase 5: mapeamento controle-cenário-custo-residual
8	Merchan-Lima et al. (2021). <i>Ann. Telecom.</i> , 76. DOI	~91	Particularidades de universidades; combinação de frameworks	Adaptação universidade: LMS, laboratórios, identidades transitórias
9	Shedden et al. (2016). <i>CAIS</i> , 39(15). DOI	~81	Ativos descobertos a partir de práticas e processos, não só inventário	Fase 1-D: discovery técnico orientado a processo
10	Hommel et al. (2015). <i>EUNIS JEHI</i> . Link	~16	Traduzir políticas universitárias para a camada tecnológica operacional	Roteiro de implantação em IES (0–12 meses)

* Sinal indicativo observado em páginas de editoras/repositórios em 17/09/2026. Não representa ranking bibliométrico universal.

Bases Normativas e Boas Práticas

A MIGR-TI/IA integra um conjunto robusto de padrões internacionais e instrumentos nacionais. Cada base normativa contribui com uma camada distinta da metodologia, desde a gestão do risco de informação até a governança responsável da inteligência artificial.

ISO/IEC 27005:2022

Contexto, identificação, análise, avaliação, tratamento, comunicação, monitoramento e revisão; alinhada ao SGSI ISO/IEC 27001. [Link](#)

NIST CSF 2.0

GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND e RECOVER; perfis atual e alvo para medir maturidade. [Link](#)

NIST SP 800-30 Rev. 1

Avaliações nos níveis organizacional, missão/processos e sistemas de informação. [Link](#)

COBIT 2019

Governança corporativa de TI e alinhamento de objetivos de negócio com objetivos de TI.

Open FAIR

Taxonomia e quantificação financeira de risco; base para análise Monte Carlo e E[L]. [Link](#)

NIST AI RMF 1.0

GOVERN, MAP, MEASURE e MANAGE para governar a IA usada na metodologia e os próprios riscos de IA. [Link](#)

HECVAT / EDUCAUSE

Avaliação de fornecedores em instituições de ensino superior; questões específicas para dados acadêmicos e de saúde. [Link](#)

MITRE ATT&CK · CISA KEV · FIRST EPSS · LGPD

Modelagem adversária, exploração conhecida, priorização preditiva e conformidade com a legislação brasileira de proteção de dados. [ATT&CK](#) | [KEV](#) | [EPSS](#) | [LGPD](#)

Princípios e Arquitetura de Ligação da MIGR-TI/IA

Os 10 Princípios Orientadores

1 Objetivos e Processos

Orientação a objetivos e processos, não somente a ativos técnicos isolados.

2 Cenários Verificáveis

Cenários de risco claros, com causa, evento central e consequência distinguíveis.

3 Quantificação Proporcional

Profundidade de análise compatível com a materialidade e incerteza do risco.

4 Participação

Donos de processos e usuários engajados no discovery e na aceitação do residual.

5 Rastreabilidade

Evidência, versionamento, auditabilidade e logs em todas as fases.

Princípios 6–10

IA como Apoio

A inteligência artificial nunca é autoridade final. Supervisão humana é obrigatória em todas as decisões materiais.

Privacidade desde o Desenho

Segurança, privacidade e ética incorporadas desde a concepção dos processos e sistemas.

Portfólio e Sistêmica

Visão de portfólio, dependências e riscos sistêmicos correlacionados.

Melhoria Contínua

Monitoramento dinâmico, aprendizagem com incidentes e revisão cíclica.

Proporcionalidade

Profundidade da análise conforme materialidade e incerteza; evitar burocracia onde não há valor.

Cadeia de Ligação com a Organização



Cada risco deve ter **dono de negócio**, **dono técnico** e **aprovador do risco residual**. Ferramentas de suporte: BPMN ou mapa de capacidades, catálogo de serviços, CMDB/grafos de conhecimento, RACI e BIA. Exemplos empresariais: vendas, produção, faturamento, P&D, RH e financeiro. Exemplos universitários: ingresso/matricula, LMS, pesquisa, laboratórios/IoT, bolsas, biblioteca e hospitais universitários.

Governança e Contexto

A Fase 0 estabelece as fundações sem as quais nenhuma fase subsequente produzirá decisões defensáveis. Escopo mal definido, apetite a risco não declarado e papéis ambíguos comprometem toda a metodologia. Esta fase é, portanto, condição habilitadora — não formalidade.

Definições Fundamentais

- Escopo: unidades, processos, tecnologias e dados cobertos
- Objetivos da avaliação e horizonte temporal
- Partes interessadas internas e externas
- Obrigações legais, regulatórias e contratuais (incluindo LGPD)
- Apetite e tolerância ao risco aprovados pelo conselho/reitoria
- Critérios de impacto: unidade monetária, categorias e limiares
- Cadência: revisão mensal, trimestral e anual independente

Três Linhas de Atuação

- **1ª linha:** donos de processos e TI — operação e controles
- **2ª linha:** segurança, GRC, DPO/jurídico — supervisão e conformidade
- **3ª linha:** auditoria interna/externa — assurance independente

Distinção de Tipos de Risco

Inerente

Risco sem nenhum controle aplicado; linha de base da exposição bruta.

Atual / Residual

Risco com os controles existentes — o que realmente existe hoje.

Alvo

Nível desejado após tratamento planejado; deve estar dentro do apetite.

Entregáveis da Fase 0

- Política de gestão de riscos de TI
- Taxonomia e categorias de risco
- Declaração de apetite e tolerância
- RACI completo com papéis e escalonamento
- Critérios de impacto e calendário de revisão
- Comitê de risco constituído

Discovery Orientado a Processos

O discovery é a fase mais trabalhosa e de maior impacto na qualidade do portfólio de riscos. Riscos não descobertos não podem ser gerenciados. A abordagem orientada a processos — conforme demonstram Shedden et al. (2016) e Spears & Barki (2010) — supera o inventário técnico isolado porque parte do que importa para a organização, não do que o scanner encontrou.



A. Discovery Organizacional

Entrevistas com dirigentes, donos de processos, usuários, docentes, TI, segurança, jurídico/DPO, auditoria, compras e fornecedores. Análise de estratégia, contratos, políticas, incidentes, auditorias e BIA existente.



C. Discovery de Dados

Catálogo, classificação, linhagem, base legal/finalidade (LGPD), retenção, localização, transferências, dados pessoais/sensíveis, pesquisa, segredos e propriedade intelectual.



E. Discovery de Terceiros

Contratos, HECVAT, SBOM, suboperadores, localização dos dados, concentração, SLA, RTO/RPO, direito de auditoria, saída e portabilidade.



B. Discovery de Processos

Mapear atividades, entradas, saídas, decisões, dependências, exceções, sazonalidade, controles manuais, trabalho remoto e pontos únicos de falha usando BPMN.



D. Discovery Técnico

CMDB, inventário de nuvem/SaaS, CSPM/CNAPP, EASM/ASM, varredura de rede e vulnerabilidade, IAM/PAM, endpoints, APIs, logs/SIEM, backups, certificados, DNS, dispositivos de laboratório e shadow IT.



F. Discovery de Ameaças

Incidentes, near misses, threat intelligence, ATT&CK, KEV, EPSS, fraude, erro humano, falha física/ambiental, indisponibilidade, risco de fornecedor e abuso interno.

Papel da IA no Discovery

Ferramentas de NLP/RAG podem extrair obrigações e riscos de contratos e políticas; classificar ativos automaticamente; realizar entity resolution, clustering e deduplicação; construir grafos de dependências; detectar anomalias e sumarizar incidentes históricos. **Exigências obrigatórias:** fontes explicitadas, nível de confiança declarado, revisão humana de todos os resultados, segregação de dados de treinamento e produção, logs completos, testes de validação e aprovação formal antes de uso em decisões.

Discriminação e Formulação de Cenários

A discriminação rigorosa entre tipos de registro é uma das contribuições mais práticas da MIGR-TI/IA. Confundir risco com vulnerabilidade, incidente ou não conformidade compromete a qualidade do portfólio e gera ruído que dificulta a tomada de decisão. Risco é definido como **efeito da incerteza sobre objetivos** — evento futuro incerto, não condição presente observada.

Distinção de Tipos de Registro

Tipo	Definição
Risco	Evento futuro incerto com impacto sobre objetivo ou processo
Vulnerabilidade	Fraqueza explorável em ativo, processo ou controle
Ameaça	Fonte ou ação potencial capaz de causar dano
Finding	Condição observada; deficiência de controle identificada
Incidente	Evento que já ocorreu; demanda resposta e lição
Issue/Problema	Condição existente que requer correção — presente, não futuro
Não Conformidade	Descumprimento comprovado de norma, lei ou política
Hipótese	Possibilidade sem evidência suficiente ainda; requer validação

Modelo de Cenário

"Devido a **[fonte de ameaça/causa]**, explorando **[vulnerabilidade ou condição]** em **[ativo/atividade/dependência]**, pode ocorrer **[evento central]**, afetando **[processo/objetivo]** e causando **[consequências]**."

Regras de Qualidade do Cenário

- Causa e consequência não podem ser confundidas nem omitidas
- Cada cenário deve ter um evento central claramente identificado
- Dividir cenários com proprietários ou tratamentos distintos
- Consolidar duplicatas com mesmo evento e consequência
- Registrar dependências, correlações e suposições
- Marcar qualidade da evidência: confirmada, indicativa ou hipótese

Classificação dos Riscos

Classificar por: origem, processo afetado, pilar CIA (confidencialidade, integridade, disponibilidade), privacidade, segurança humana, continuidade, financeiro, regulatório, reputação, integridade acadêmica/científica, terceiros, projeto, modelo/IA e risco sistêmico. Itens que não são riscos permanecem em registros próprios (finding, issue, backlog), ligados aos cenários de risco que alteram.

O Que Incluir, Destacar e Excluir do Registro

✓ Incluir quando houver:

- Objetivo ou processo afetado identificável
- Cenário plausível com evento central
- Consequência material estimável
- Proprietário definido (negócio e técnico)
- Evidência ou hipótese explicitada

Incluir riscos de: cibernéticos, disponibilidade, integridade, confidencialidade, privacidade, fraude, terceiros, nuvem, supply chain, obsolescência, capacidade, pessoas, físico/ambiental, continuidade, projetos, dados, IA/modelos, conformidade, ética e reputação.

🚩 Destacar com flags obrigatórias:

1. Vida, saúde ou segurança humana
2. Obrigação legal/regulatória ou LGPD
3. Exploração conhecida (CISA KEV) ou ataque ativo
4. Processo crítico com RTO/RPO ameaçado
5. Dados pessoais sensíveis, grande volume ou pesquisa estratégica
6. Risco sistêmico ou ponto único de falha
7. Concentração em terceiro, nuvem ou identidade
8. Baixa probabilidade, impacto catastrófico
9. Risco emergente ou crescimento rápido
10. Alta incerteza ou evidência fraca
11. Risco de IA: discriminação, alucinação, prompt injection, deriva

✗ Não inserir como risco autônomo:

- Cada CVE individual sem cenário associado
- Alertas brutos de ferramentas sem triagem
- Ativos sem dono definido (é um issue)
- Tarefas atrasadas sem impacto avaliado
- Controles ausentes sem cenário de risco associado
- Duplicatas do mesmo evento e consequência

Manter esses itens em **backlog/finding/issue** e agregar ao cenário correspondente. Exceções materiais entram por gatilho obrigatório.

- 📋 Criar lista "Top Risks" executiva separada do registro completo, com tendência, confiança, exposição, dono e próxima decisão.

Análise, Quantificação e Priorização de Vulnerabilidades

Conforme demonstrado por Cox (2008), matrizes de risco ordinais podem inverter prioridades, comprimir diferenças reais e alocar recursos de forma subótima. A MIGR-TI/IA usa triagem qualitativa apenas para encaminhamento inicial — não como mecanismo de ordenação ou investimento. Para riscos materiais, a quantificação segue o modelo Open FAIR com simulação Monte Carlo.

Quantificação FAIR / Monte Carlo

01

Frequência Anual de Eventos (LEF)

Modelada como distribuição (mínimo, mais provável, máximo) — não como ponto único.

02

Magnitude de Perda (LM)

Faixas/distribuições: resposta, recuperação, produtividade, receita, responsabilidade, multas (quando juridicamente aplicáveis) e reputação estimada.

03

Métricas de Saída

Perda anual esperada $E[L]$; percentis P90/P95; CVaR (medida de cauda); risco inerente, atual e residual/alvo; intervalos de confiança; correlação e agregação de portfólio.

Priorização de Vulnerabilidades

Combinar **múltiplos sinais** — não apenas CVSS isolado:

- Criticidade do processo/ativo afetado
- Exposição: interna, perimetral ou externa
- Técnicas ATT&CK aplicáveis ao cenário
- Presença na CISA KEV (exploração confirmada)
- EPSS: probabilidade de exploração em 30 dias
- CVSS: severidade técnica (input, não saída)
- Privilégios necessários e blast radius
- Controles compensatórios existentes

BIA — Análise de Impacto no Negócio

- MTPD/MAO: tempo máximo de perturbação aceitável
- RTO: objetivo de tempo de recuperação
- RPO: objetivo de ponto de recuperação de dados
- Dependências críticas e efeitos em cascata

Corte Razoável — Os Quatro Portões

O corte não deve ser um "score mágico" que descarta riscos mecanicamente. A MIGR-TI/IA usa quatro portões sequenciais e hierárquicos. Os portões A e B são não discricionários — nenhuma análise econômica pode os sobrepor.

1

Portão A — Não Discricionário

Segurança humana, ilegalidade, obrigação regulatória, risco sem possibilidade legítima de aceitação e exploração ativa relevante **não podem ser descartados** pelo corte financeiro. Acionar escalonamento imediato.

2

Portão B — Appetite / Tolerância

Tratar ou escalar se E[L], P95/CVaR, indisponibilidade, perda de dados, número de titulares ou outro KRI exceder o limite aprovado na Fase 0. Parâmetros definidos pelo conselho/reitoria.

3

Portão C — Economia Marginal

Priorizar controles cujo benefício esperado incremental — $E[L \text{ antes}] - E[L \text{ depois}]$ — exceda o custo total do controle e efeitos colaterais. Usar Gordon-Loeb como referência econômica, não como regra fixa de 37%.

4

Portão D — Capacidade / Portfólio

Escolher conjunto de tratamentos que maximize redução esperada e resiliência sob orçamento, pessoas, dependências e prazo. Preservar riscos de cauda e sistêmicos mesmo com E[L] moderado.

Quatro Decisões Possíveis



Agir Imediatamente

Qualquer flag obrigatória verdadeira, P95 acima da tolerância ou processo crítico além do MTPD.



Tratar no Ciclo

Benefício líquido positivo; residual acima do apetite; ação planejada com dono e prazo.



Monitorar / Aceitar

Aceitação formal com dono de negócio, prazo definido e gatilhos de reabertura explicitados.



Arquivar

Baixa materialidade confirmada; justificativa registrada; gatilho de reabertura definido. Revisão trimestral.



Calibrar o corte por backtesting de incidentes e near misses, análise de sensibilidade, curvas de benefício/custo e taxa de falsos negativos. Realizar piloto de 8–12 semanas e revisar trimestralmente. Um risco pode ser destacado pela cauda mesmo com perda esperada moderada — não confundir linha de destaque executivo com linha de tratamento.

Tratamento de Riscos

O tratamento conecta cada cenário de risco a controles específicos com estimativa de eficácia, custo, prazo, dependências e risco residual esperado. Conforme Fenz et al. (2011), o vínculo explícito entre risco, controle e custo é condição necessária para decisões de investimento defensáveis. Nenhum controle deve existir sem rastreabilidade ao cenário que mitiga.

Quatro Opções de Tratamento

Evitar

Eliminar a atividade, processo ou dependência que origina o risco. Aplicável quando o custo-benefício é desfavorável ou o risco não é aceito.

Reduzir

Implementar controles preventivos, detectivos, responsivos e de recuperação para diminuir frequência e/ou magnitude.

Transferir / Compartilhar

Seguro cibernético, SLA contratual com terceiros, cláusulas de responsabilidade e indenização.

Aceitar

Aceitação formal com dono de negócio, justificativa documentada, prazo e gatilhos de reavaliação.

Controles Prioritários por Domínio

- **Identidade:** MFA resistente a phishing, zero trust, privilégio mínimo, PAM, identidade federada
- **Rede:** microssegmentação, SASE/SSE, monitoramento de tráfego leste-oeste
- **Aplicações:** secure SDLC, SAST/DAST, gestão de segredos, assinatura de artefatos, SBOM
- **Dados:** classificação, DLP, criptografia em repouso e trânsito, controle de acesso baseado em papel
- **Continuidade:** backups imutáveis testados, RTO/RPO validados, BCP/DRP exercitados
- **Fornecedores:** HECVAT, cláusulas contratuais, direito de auditoria, exit plan
- **Pessoas:** conscientização baseada em função, phishing simulado, treinamento para pesquisadores
- **Resposta:** playbooks por cenário, tabletop semestral, parceria com CSIRT/SOC

Cada plano de ação deve conter: ação específica, dono responsável, prazo, evidência de conclusão e critério de aceite.

Uso Responsável de Inteligência Artificial

A IA é um acelerador da gestão de riscos, não um substituto para o julgamento humano. Esta distinção é operacional: a MIGR-TI/IA define explicitamente o que a IA pode e não pode fazer, alinhada ao NIST AI RMF 1.0 (GOVERN, MAP, MEASURE, MANAGE) e à ISO/IEC 42001 quando adotada.

✓ Casos de Uso Permitidos (com humano no circuito)

- Extração de obrigações e riscos de contratos e políticas (NLP/RAG)
- Classificação automática de ativos e dados
- Correlação de eventos e anomalias em logs/SIEM
- Priorização assistida de vulnerabilidades
- Previsão de tendências de risco e KRIs
- Simulação de cenários (Monte Carlo assistido)
- Sumarização de incidentes e relatórios executivos
- Construção e atualização de grafos de dependência

⊘ Proibições e Limites Absolutos

- IA não aceita risco residual autonomamente
- IA não aprova exceções de política
- IA não encerra findings materiais sem validação humana
- IA não decide sanções ou ações de alto impacto
- IA não é "dona" de nenhum risco no registro

Controles Obrigatórios para Componentes de IA

- Inventário de modelos: finalidade, dados, fornecedor, versão
- Testes, métricas e explicabilidade proporcional ao risco
- RAG com fontes explicitadas e nível de confiança
- Proteção contra prompt injection e DLP
- Avaliação de viés, drift, robustez e red team de IA
- Logs completos e capacidade de rollback
- Revisão independente periódica

📌 Os riscos dos próprios componentes de IA (discriminação, alucinação, prompt injection, vazamento, deriva, automação indevida, supply chain do modelo) devem ser tratados no mesmo registro de riscos da metodologia, com os mesmos campos e flags — inclusive o flag 11 da Fase 2.

Monitoramento, Métricas e Aprendizagem Contínua

Gestão de riscos sem monitoramento dinâmico é uma fotografia, não um processo. Webb et al. (2014) demonstram que percepção situacional contínua — percepção, compreensão e projeção — é o mecanismo que transforma avaliações pontuais em capacidade organizacional. A Fase 7 fecha o ciclo e alimenta todas as fases anteriores.

Gatilhos Obrigatórios de Reavaliação

- Mudança relevante de arquitetura ou tecnologia
- Novo fornecedor, aquisição ou migração de sistema
- Incidente ou near miss significativo
- Nova regulação ou alteração de obrigação legal
- Implantação de novo modelo de IA
- Novos dados ou ultrapassagem de tolerância de KRI

Cadência de Revisão

- **Mensal:** revisão operacional de KRIs, controles e incidentes
- **Trimestral:** revisão executiva do portfólio e corte
- **Anual:** auditoria independente e revisão completa
- **Pós-incidente:** atualização de cenários e premissas

Métricas de Desempenho da Metodologia

- Cobertura de processos críticos e ativos descobertos
- % de riscos com dono e evidência documentados
- Tempo médio de discovery até decisão
- Exposição agregada acima do apetite (E[L] e P95)
- Eficácia de controles e risco residual por domínio
- Tempo de correção de itens CISA KEV
- Restauração testada vs. RTO/RPO declarado
- Concentração em terceiros e fornecedores críticos
- Taxa de riscos reabertos, incidentes não previstos e falsos negativos
- **IA:** precisão, recall, calibração, drift e taxa de override humano

Modelo de Registro de Risco

O registro de risco é o artefato central da MIGR-TI/IA. Cada entrada conecta o cenário ao objetivo estratégico, ao processo, ao tratamento e ao monitoramento. Os campos abaixo são obrigatórios para riscos no plano de tratamento; campos marcados como opcionais aplicam-se conforme materialidade.

Grupo	Campo	Descrição / Valores
Identificação	ID único; objetivo estratégico; processo/atividade; serviço de TI	Rastreabilidade à cadeia estratégica
Propriedade	Dono de negócio; dono técnico; aprovador do residual	Papéis humanos — nunca IA
Cenário	Ativo/dado; causa/ameaça; vulnerabilidade; evento central; consequências	Modelo: "Devido a... explorando... pode ocorrer..."
Requisitos	Requisitos legais, regulatórios e contratuais aplicáveis	LGPD, setorial, contratual
Controles	Controles existentes; eficácia estimada; evidências/fontes	Vínculo explícito cenário-controle-custo
Quantificação	Frequência anual (LEF); magnitude (LM); E[L]; P95/CVaR	Distribuições, não pontos únicos
Níveis de Risco	Inerente; atual/residual; alvo	Antes e após controles planejados
Classificação	Flags obrigatórias (1–11); nível de confiança da evidência	Independente da pontuação quantitativa
Decisão	Agir / Tratar / Monitorar / Arquivar; plano; prazo	Portões A–D aplicados
Monitoramento	KRI/gatilhos; dependências correlacionadas; última revisão; próxima revisão	Cadência definida na Fase 7
Aceitação	Aceitação formal: dono de negócio, data, prazo de expiração, gatilho de reabertura	Obrigatório para riscos aceitos acima do apetite

Adaptação: Empresa vs. Universidade

A MIGR-TI/IA aplica-se a ambos os contextos, mas requer adaptações substanciais em governança, identidades, dados e tecnologia. Merchan-Lima et al. (2021) e Hommel et al. (2015) documentam as particularidades das IES, enquanto a literatura corporativa e o COBIT 2019 sustentam a dimensão empresarial.

Dimensão	Empresa	Universidade / IES
Objetivo Dominante	Receita, produção, cliente, market share	Ensino, pesquisa, extensão, missão pública
Governança	Centralização variável; hierarquia executiva	Colegiada, descentralizada; autonomia de unidades
Identities	Força de trabalho estável; parceiros definidos	Ciclo intenso de alunos, visitantes, pesquisadores e prestadores
Dados Críticos	Clientes, financeiro, propriedade intelectual comercial	Estudantes, pesquisa, saúde (HU), integridade acadêmica, dados de menores quando aplicável
Tecnologia	ERP, CRM, OT industrial, e-commerce	LMS, laboratórios, HPC, federação de identidade, BYOD intenso
Terceiros	Cadeia comercial, fornecedores industriais	Edtech, publishers, nuvem científica, parceiros de pesquisa, HECVAT
Continuidade	Operação e receita; SLA com clientes	Calendário acadêmico, matrículas, avaliações, pesquisa em andamento
Controles	Adequar à eficiência operacional	Adequar sem impedir liberdade acadêmica e colaboração científica

Destaques Específicos para Universidades

Dados de estudantes e saúde, dados de menores quando aplicável, pesquisa sensível e propriedade intelectual científica, integridade científica e acadêmica, liberdade acadêmica como valor a preservar, laboratórios IoT/OT expostos, redes abertas e visitantes, identidades transitórias com acesso prolongado indevido, descentralização e shadow IT departamental, e continuidade do calendário acadêmico como RTO institucional.

Exemplos Hipotéticos Completos

Os cenários a seguir são exemplos hipotéticos elaborados para fins didáticos. Não representam incidentes reais e os valores numéricos são ilustrativos, produzidos para demonstrar a aplicação da metodologia.

Exemplo 1 — Empresa: Comprometimento de Identidade e Ransomware em ERP/SaaS de Faturamento

Campo	Conteúdo
Objetivo	Faturamento contínuo e integridade de dados financeiros
Processo	Emissão de notas fiscais; integração ERP-SaaS-banco; conciliação financeira
Dependências	ERP on-premise; SaaS de faturamento; integração bancária via API; IdP corporativo; VPN de acesso remoto
Cenário	"Devido à ausência de MFA resistente a phishing e reutilização de credenciais, explorando campanha de spear-phishing direcionada ao time financeiro, pode ocorrer comprometimento de conta privilegiada com implantação de ransomware no ERP e exfiltração de dados financeiros, afetando o processo de faturamento e causando indisponibilidade operacional, multas fiscais, perda de receita e dano reputacional."
Flags	🚩 Obrigação legal/fiscal · 🚩 Processo crítico com RTO ameaçado · 🚩 Dados financeiros de clientes · 🚩 Exploração ativa de técnica ATT&CK T1566/T1078
Quantificação (hipotética)	LEF: 0,15–0,40/ano; LM: R\$ 800K–R\$ 4,5M (resposta: R\$ 200K; recuperação: R\$ 300K; multa fiscal: R\$ 150K; receita: R\$ 2M; reputação: R\$ 850K estimado); E[L] ≈ R\$ 620K/ano; P95 ≈ R\$ 3,2M
Decisão	Portão A + B: agir imediatamente. P95 excede tolerância de R\$ 1M aprovada.
Tratamento	MFA phishing-resistant (FIDO2) em 30 dias; PAM para contas ERP; segmentação da rede de faturamento; backup imutável testado semanalmente; playbook ransomware com RTO de 4h; SIEM com alerta de comportamento anômalo de conta financeira; treinamento de conscientização para o time financeiro.
Residual Esperado	E[L] ≈ R\$ 180K/ano; P95 ≈ R\$ 850K — dentro do apetite aprovado.

Exemplo 2 — Universidade: Credencial Comprometida, Exfiltração de Dados e Interrupção do LMS

Campo	Conteúdo
Objetivo	Continuidade do ensino e proteção de dados de estudantes e pesquisa
Processo	Matrícula; acesso ao LMS; pesquisa com dados sensíveis; armazenamento em nuvem científica
Dependências	IdP federado (SAML/OIDC); LMS SaaS; fornecedor de nuvem científica; identidades de ex-alunos não revogadas; BYOD sem MDM
Cenário	"Devido à ausência de revisão periódica de identidades transitórias e falha no processo de offboarding de ex-alunos, explorando credencial de ex-pesquisador não revogada com acesso ao bucket de pesquisa na nuvem, pode ocorrer acesso não autorizado e exfiltração de dados de pesquisa sensível (incluindo dados de saúde de participantes) e interrupção do LMS durante período de avaliações, causando violação da LGPD, notificação à ANPD, prejuízo à integridade científica e interrupção do calendário acadêmico."
Flags	🚩 LGPD: dados pessoais sensíveis (saúde) · 🚩 Processo crítico: calendário e avaliações · 🚩 Dados de pesquisa estratégica · 🚩 Concentração em fornecedor de nuvem · 🚩 Identidades transitórias (alta rotatividade)
HECVAT	Fornecedor de nuvem científica avaliado; lacunas identificadas em subprocessadores e localização de dados no Brasil; cláusula de auditoria ativada; exit plan solicitado em 60 dias.
Quantificação (hipotética)	LEF: 0,20–0,45/ano; LM: R\$ 600K–R\$ 3,8M (resposta LGPD: R\$ 300K; notificação: R\$ 80K; multa estimada ANPD: R\$ 200K; produtividade acadêmica: R\$ 500K; reputação científica: R\$ 2M); E[L] ≈ R\$ 560K/ano; P95 ≈ R\$ 2,9M
Decisão	Portões A + B: agir imediatamente. Flags LGPD e continuidade acadêmica não discricionárias.
Tratamento	Revisão e revogação imediata de identidades inativas; MFA para acesso ao LMS e nuvem científica; processo de offboarding automatizado; DLP no bucket de pesquisa; RACI de dados pessoais com DPO; DPIA para dados de saúde; teste de restauração do LMS com RTO de 2h; tabletop de continuidade acadêmica semestral.

Roteiro de Implantação, Papéis e Conclusão

Roteiro de Implantação (0–12 meses)

0–30 dias: Governança e Escopo

Constituir comitê; definir escopo e taxonomia; apetite provisório; escolher 3–5 processos críticos; RACI; fontes de dados e ferramentas.

61–90 dias: Quantificação e Paineis

Quantificar top riscos com FAIR; calibrar corte pelos quatro portões; decidir tratamentos prioritários; criar painel executivo; perfil NIST atual e alvo.

6–12 meses: Maturidade e Automação

Portfólio quantitativo completo; automação contínua de KRIs; auditoria independente; avaliação de maturidade; ciclo de melhoria contínua.

1

2

3

4

5

31–60 dias: Discovery e Triagem

Mapas processo-ativo-dado; 20–40 cenários iniciais; triagem qualitativa; piloto de IA em ambiente controlado; BIA e qualidade de dados.

3–6 meses: Expansão e Terceiros

Ampliar cobertura de processos; avaliar fornecedores (HECVAT); tabletops; testes de restauração; assurance de componentes de IA.

Papéis e Responsabilidades

Conselho / Reitoria / Diretoria

Aprova apetite e tolerância; recebe relatório executivo trimestral; decide sobre riscos de cauda.

Comitê de Risco de TI

Prioriza portfólio; aprova cortes; decide sobre tratamentos de custo relevante; alinha com objetivos estratégicos.

Dono do Processo de Negócio

Responde pelo impacto; participa do discovery; aceita formalmente o risco residual com justificativa e prazo.

TI / Segurança da Informação

TI mantém serviços e controles técnicos; segurança facilita a metodologia, monitora e coordena resposta.

DPO / Jurídico / Auditoria

DPO/jurídico avalia privacidade e LGPD; auditoria fornece assurance independente e valida o processo.

Conclusão

A MIGR-TI/IA demonstra que a gestão de riscos em TI eficaz começa no objetivo estratégico e no processo de negócio, passa por discovery contínuo e orientado a práticas organizacionais, formula cenários discriminados com causa, evento e consequência claramente distinguíveis, quantifica na profundidade proporcional à materialidade e à decisão em jogo, aplica cortes governados por quatro portões hierárquicos — e não por um score arbitrário — e usa inteligência artificial como acelerador com rastreabilidade completa e autoridade humana preservada em todas as decisões materiais.

Matrizes de calor simples podem servir como visualização executiva, mas não como mecanismo único de ordenação, priorização ou decisão de investimento — conforme demonstrado por Cox (2008) e corroborado pela convergência entre Open FAIR, ISO/IEC 27005:2022 e NIST SP 800-30. A participação de donos de processos e usuários, evidenciada por Spears & Barki (2010), não é opcional: é o fator que distingue um portfólio de riscos útil de um exercício de conformidade sem impacto.

Referências

- Boehm (1991): doi.org/10.1109/52.62930
- Cox (2008): doi.org/10.1111/j.1539-6924.2008.01030.x
- Gordon & Loeb (2002): doi.org/10.1145/581271.581274
- Spears & Barki (2010): misq.umn.edu
- Webb et al. (2014): doi.org/10.1016/j.cose.2014.04.005
- Culot et al. (2021): doi.org/10.1108/TQM-09-2020-0202
- Fenz et al. (2011): doi.org/10.17705/1CAIS.02822
- Merchan-Lima et al. (2021): doi.org/10.1007/s12243-020-00783-2
- Shedden et al. (2016): doi.org/10.17705/1CAIS.03915
- Hommel et al. (2015): eunis.org/erai/2015-3
- ISO/IEC 27005:2022: iso.org/standard/80585.html
- NIST CSF 2.0: nist.gov/cyberframework
- NIST SP 800-30 Rev.1: csrc.nist.gov
- NIST AI RMF 1.0: nist.gov/itl/ai-risk-management-framework
- Open FAIR: opengroup.org/open-fair
- HECVAT/EDUCAUSE: educause.edu
- CISA KEV: cisa.gov/known-exploited-vulnerabilities-catalog
- FIRST EPSS: first.org/epss
- MITRE ATT&CK: attack.mitre.org
- LGPD: planalto.gov.br — Lei 13.709/2018